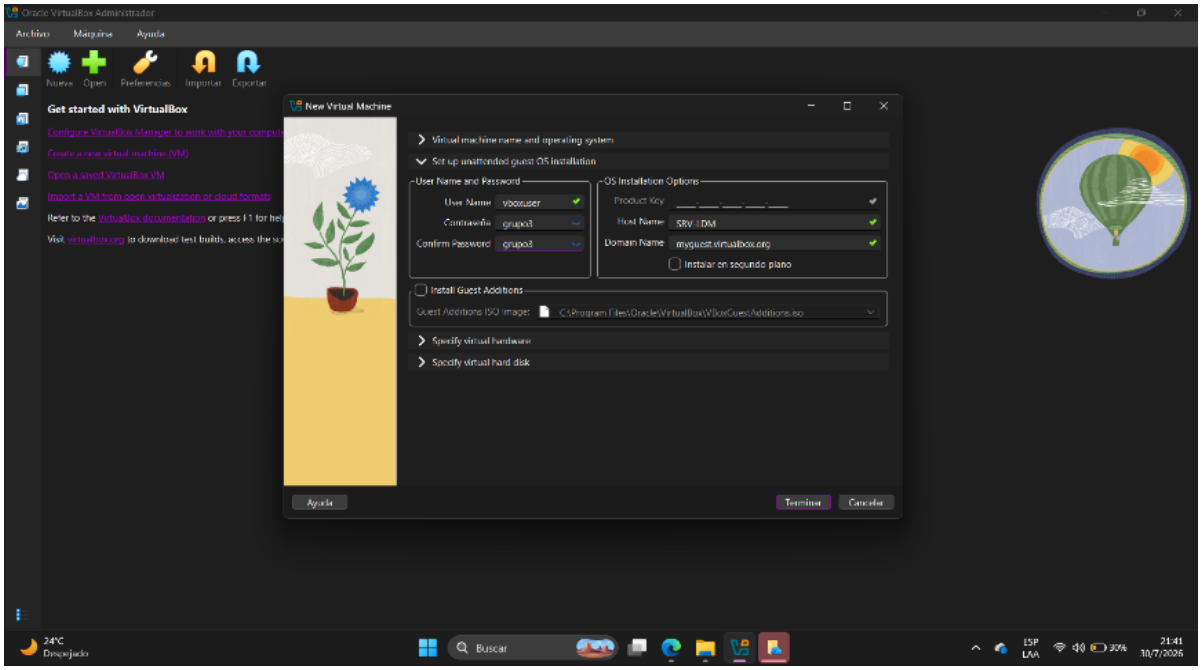
Evidencia Explicada

Componente 2: Sistemas Operativos y Almacenamiento

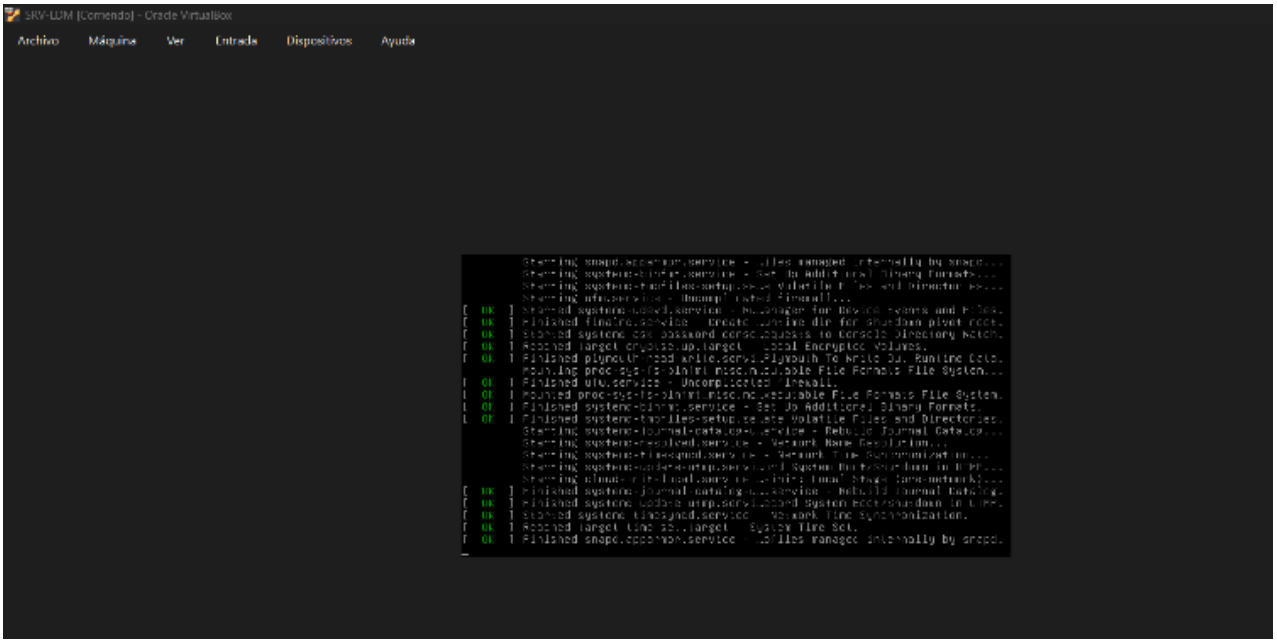
Este documento explica, captura por captura, cada paso ejecutado en la máquina virtual (SRV-LDM, Ubuntu Server) para resolver el incidente del Componente 2: kernel sin parches, registros de autenticación sin protección en la partición raíz y ausencia de cuotas de disco que provocó la corrupción del sistema de archivos ext4. Cada bloque de evidencia se agrupa por fase del proceso e incluye el motivo técnico de por qué se ejecutó cada acción.

Creación de la Máquina Virtual

Se utilizó Oracle VirtualBox para levantar un servidor Ubuntu Server desde cero, simulando el servidor de aplicaciones descrito en el incidente.

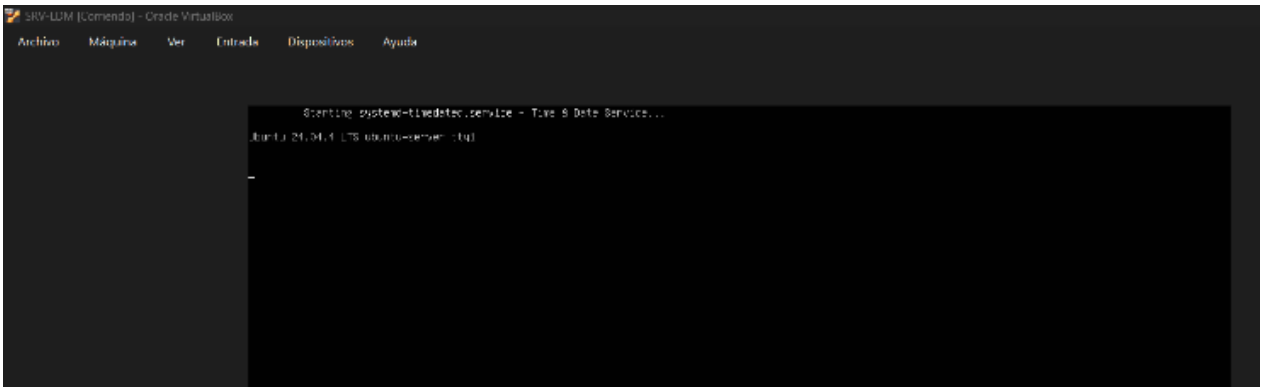


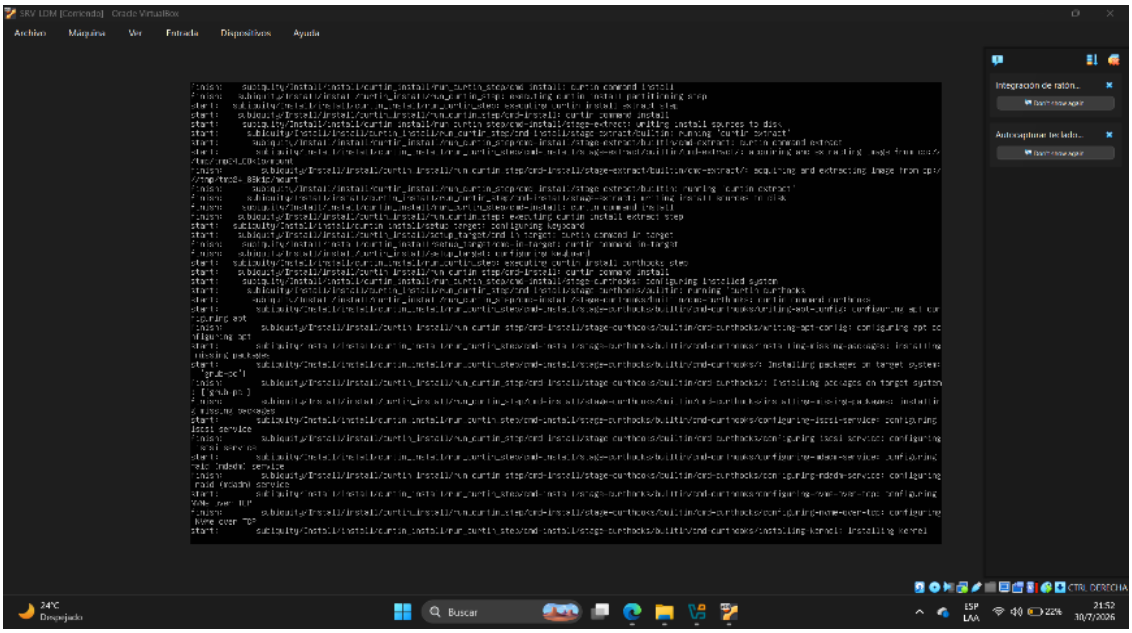
Arranque inicial de la máquina virtual mostrando el proceso de carga del kernel de Linux y los servicios iniciando uno por uno hasta alcanzar el modo multiusuario.



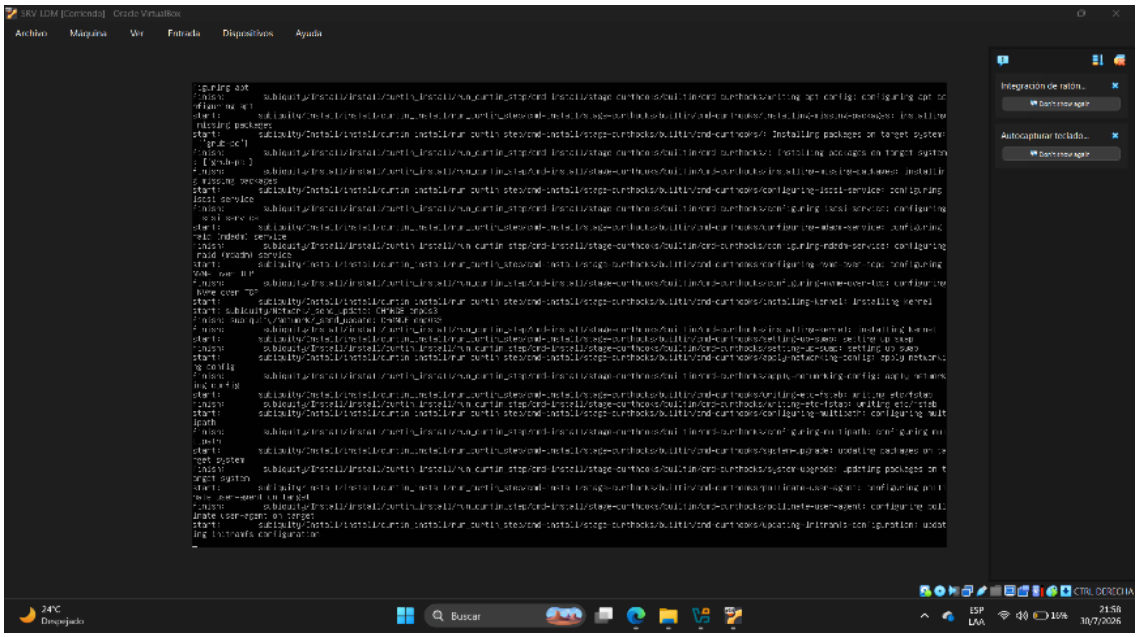
Instalación de Ubuntu Server

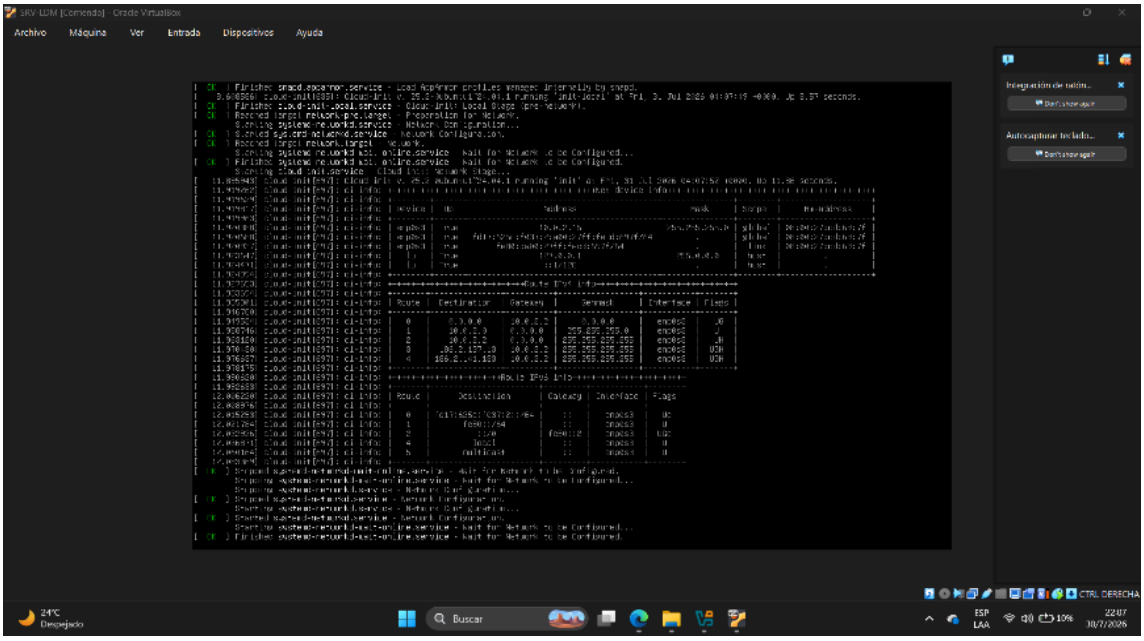
Se documentó el proceso de instalación (Subiquity/curtin installer) para dejar evidencia de que el sistema operativo se instaló desde una imagen oficial y actualizada.



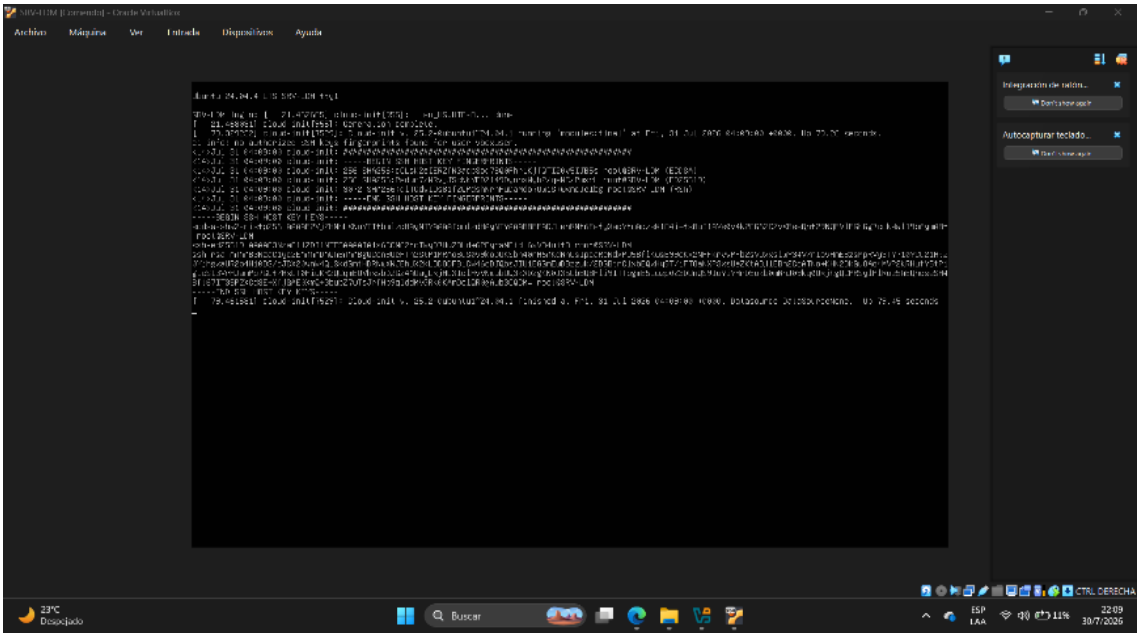


El sistema muestra la versión de Ubuntu instalada, el estado de las actualizaciones disponibles y confirma la creación exitosa de la cuenta de administrador con permisos de sudo (grupo sudo/administradores).

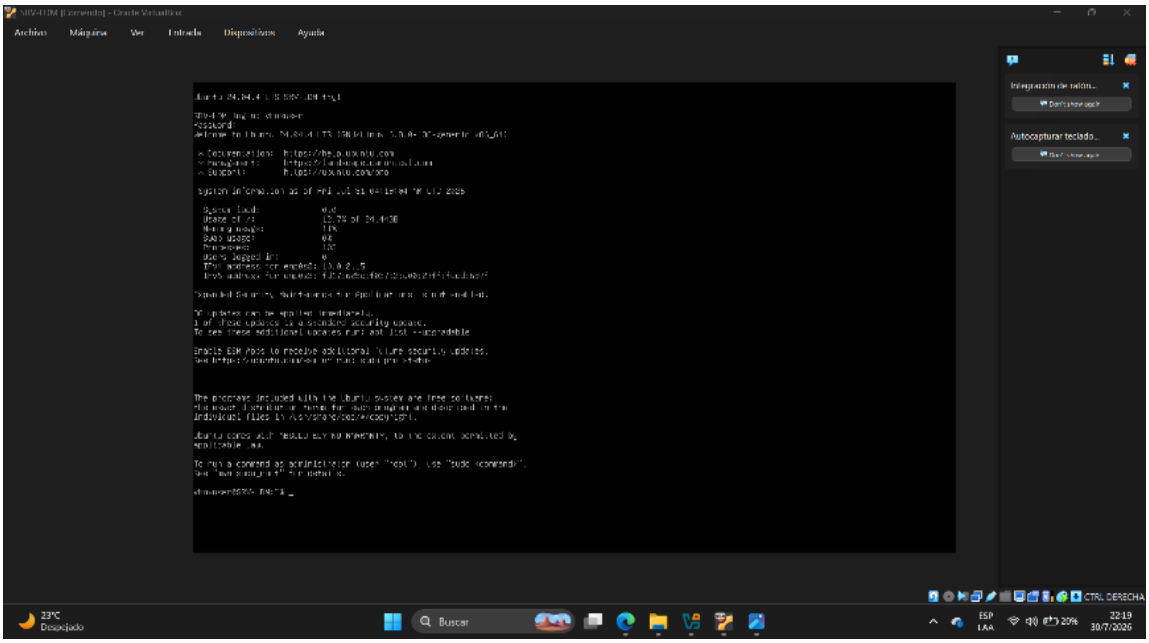




Verificación del Panel de la Máquina Virtual

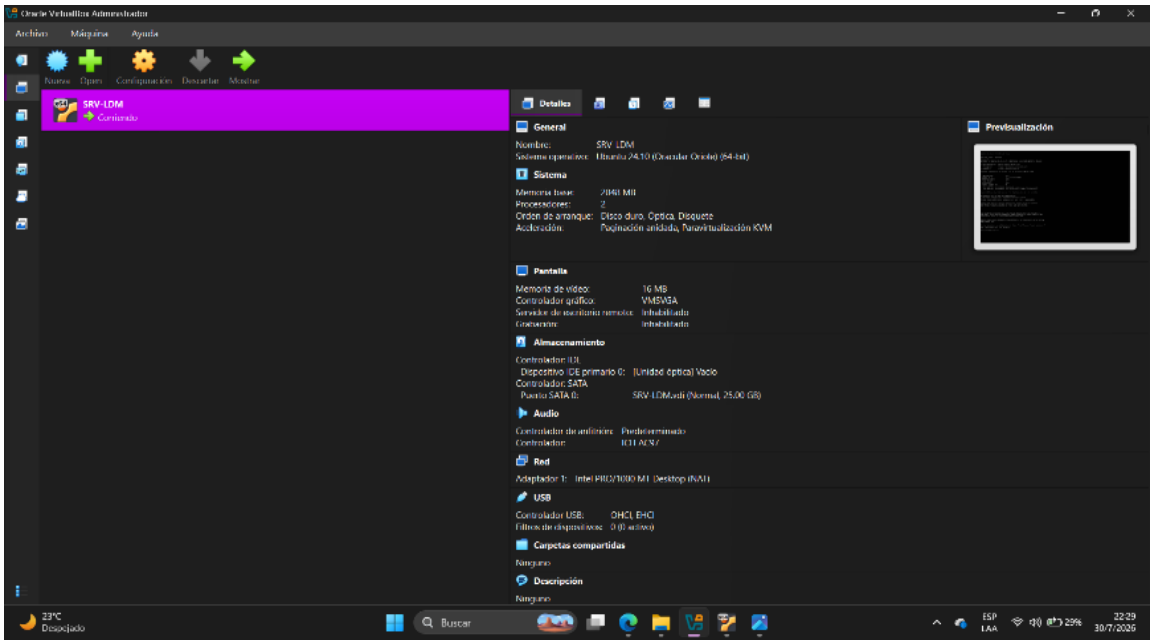


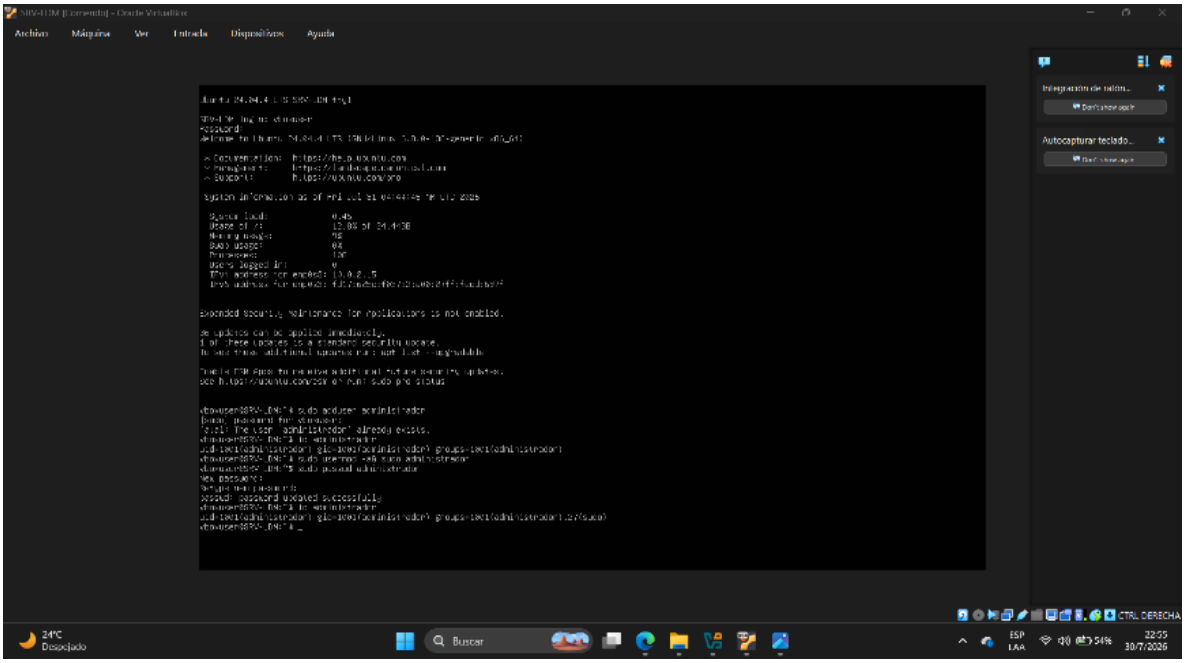
Sistema operativo Ubuntu de 64 bits, 2048 MB de memoria base, 2 procesadores virtuales y aceleración por paginación anidada.



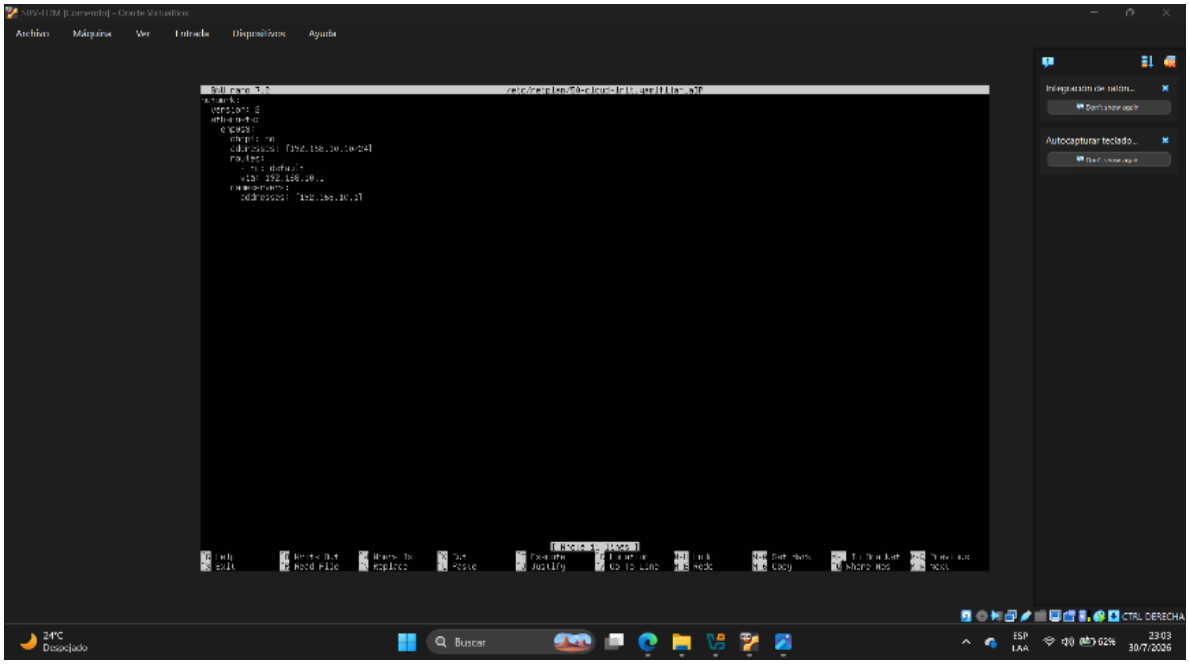
Configuración de Red Estática (Netplan)

Se fijo una IP estática en el servidor de sistemas operativos para poder administrar el equipo de forma consistente (SSH, fail2ban, etc.) y no depender de direcciones IP asignadas dinámicamente por DHCP, que cambiarían en cada reinicio.

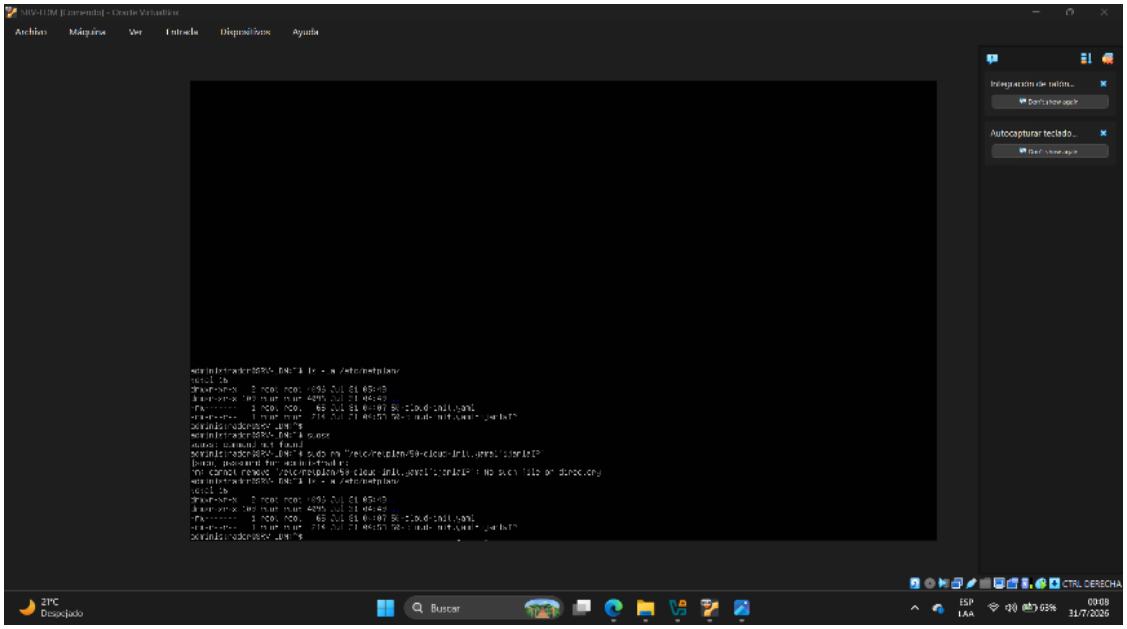




Se deshabilita DHCP (dhcp4: no) y se asigna la dirección IP estática 192.168.10.30/24, con puerta de enlace 192.168.10.1 y servidor DNS 8.8.8.8.

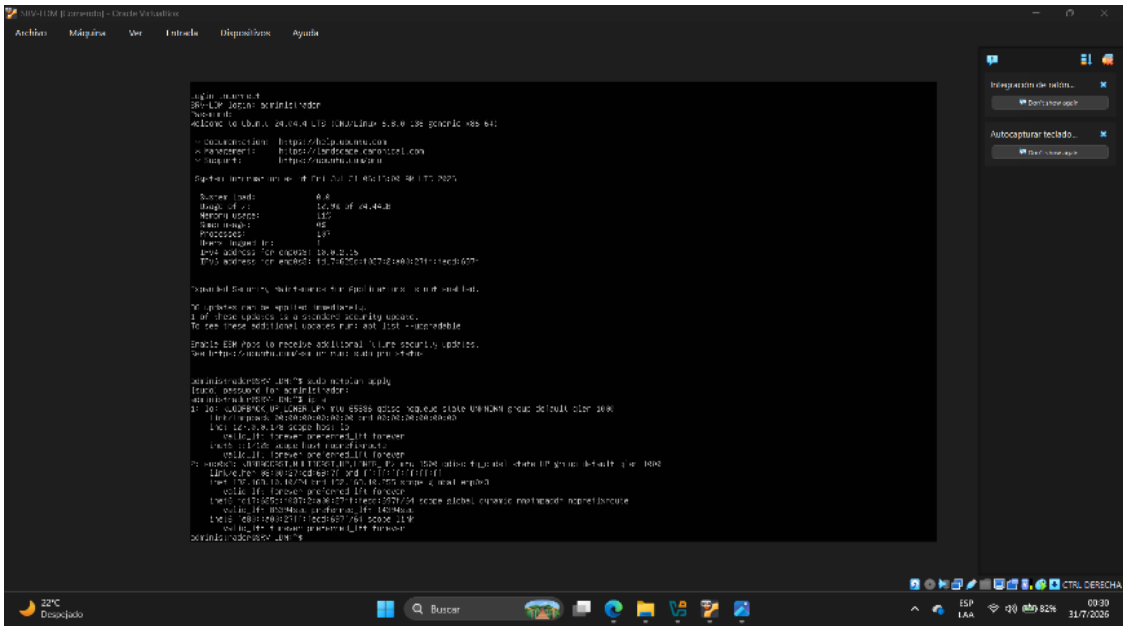


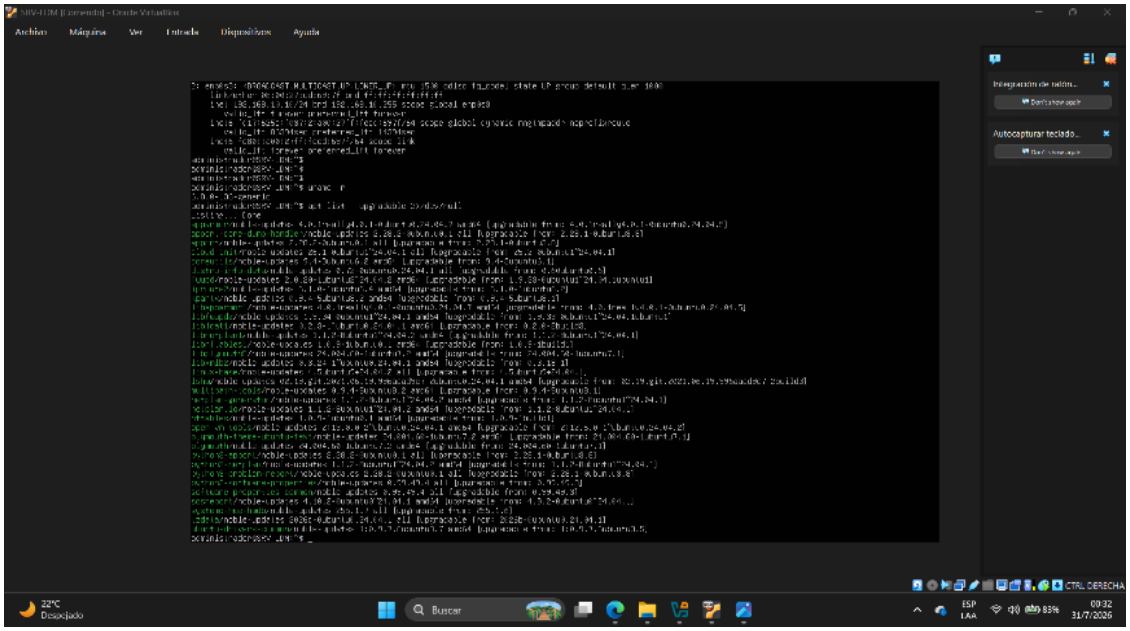
Ejecución del comando sudo netplan apply para aplicar la nueva configuración de red sin necesidad de reiniciar el servidor.



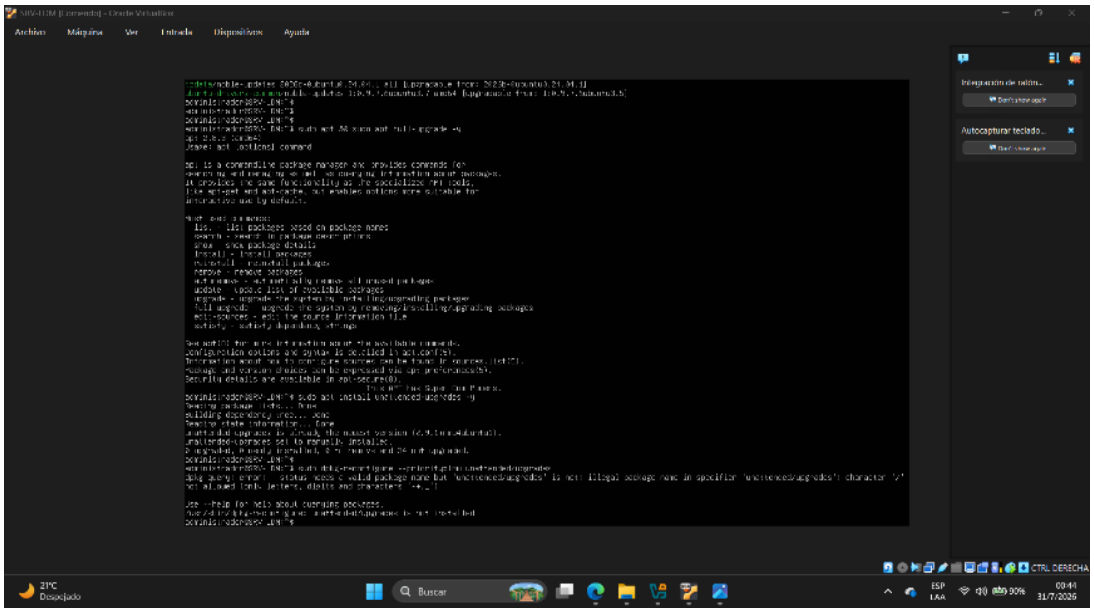
Gestión de Usuarios y Principio de Menor Privilegio

Se crea una cuenta de usuario independiente del usuario inicial de instalación, para separar responsabilidades y evitar el uso permanente de una única cuenta con privilegios totales (alineado con el control de gestión de identidades de ISO 27001.)





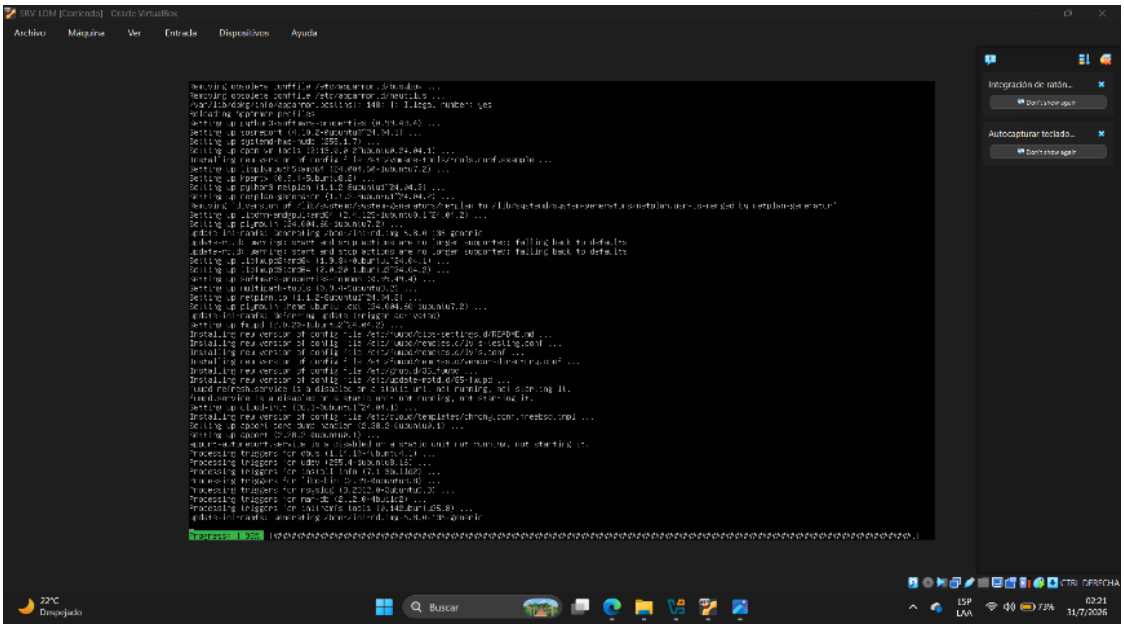
Verificación de que el nuevo usuario fue agregado correctamente al grupo sudo, lo que le permite ejecutar comandos administrativos sin usar la cuenta root directamente.



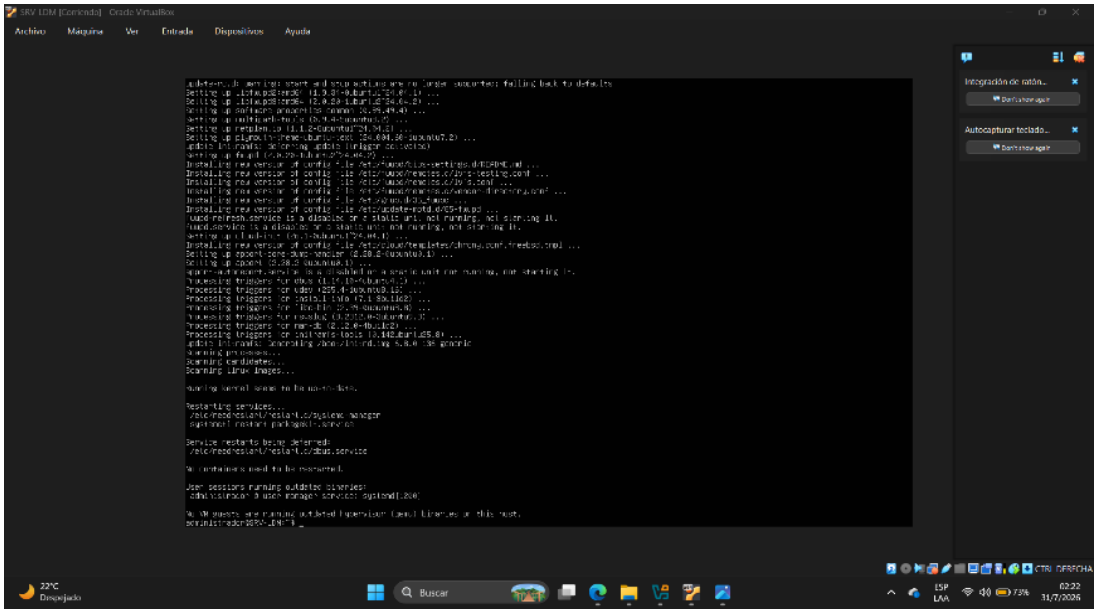
Listado de los grupos y permisos asociados a la nueva cuenta, confirmando la correcta segregación de privilegios.

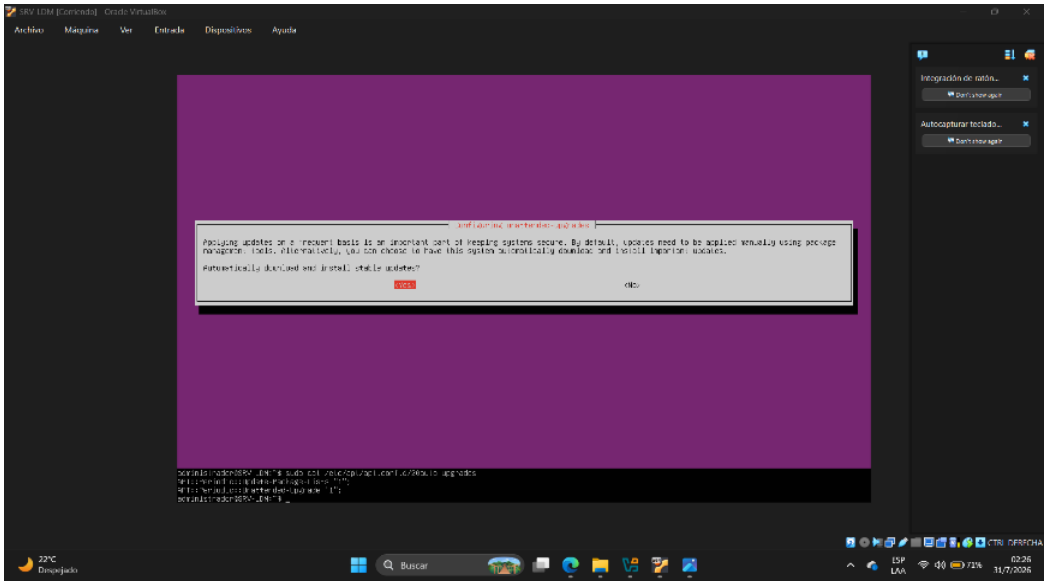
Actualización del Sistema (Parcheo del Kernel)

El kernel llevaba 24 meses sin parches. La contramedida directa es forzar la actualización completa del sistema, cerrando la ventana de exposición a vulnerabilidades conocidas (mapeado al control ISO 27001 A.8.8 — Gestión de vulnerabilidades técnicas).



Ejecución de sudo apt update, actualizando el índice local de paquetes disponibles desde los repositorios oficiales de Ubuntu.

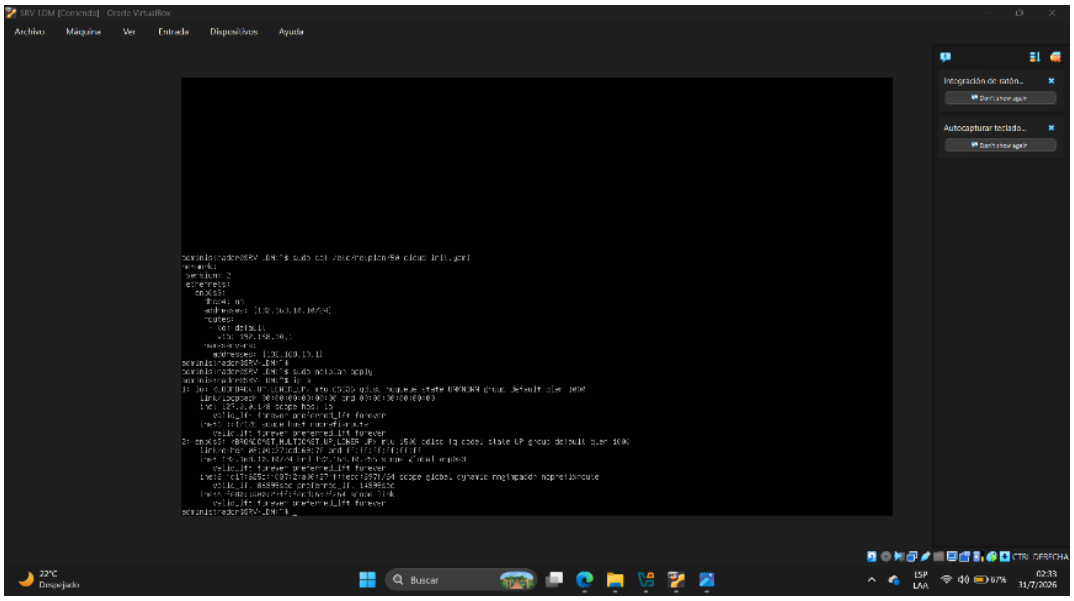




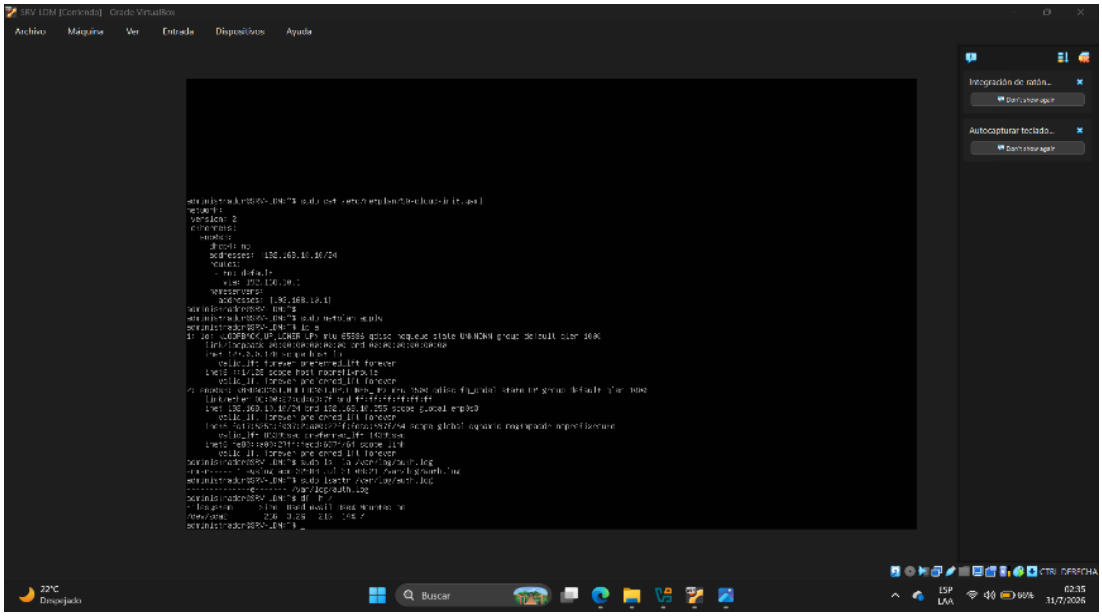
Confirmación de que el sistema no tiene actualizaciones pendientes tras el proceso, y verificación de la nueva versión de kernel activa con el comando uname -r.

Hardening del Servicio SSH

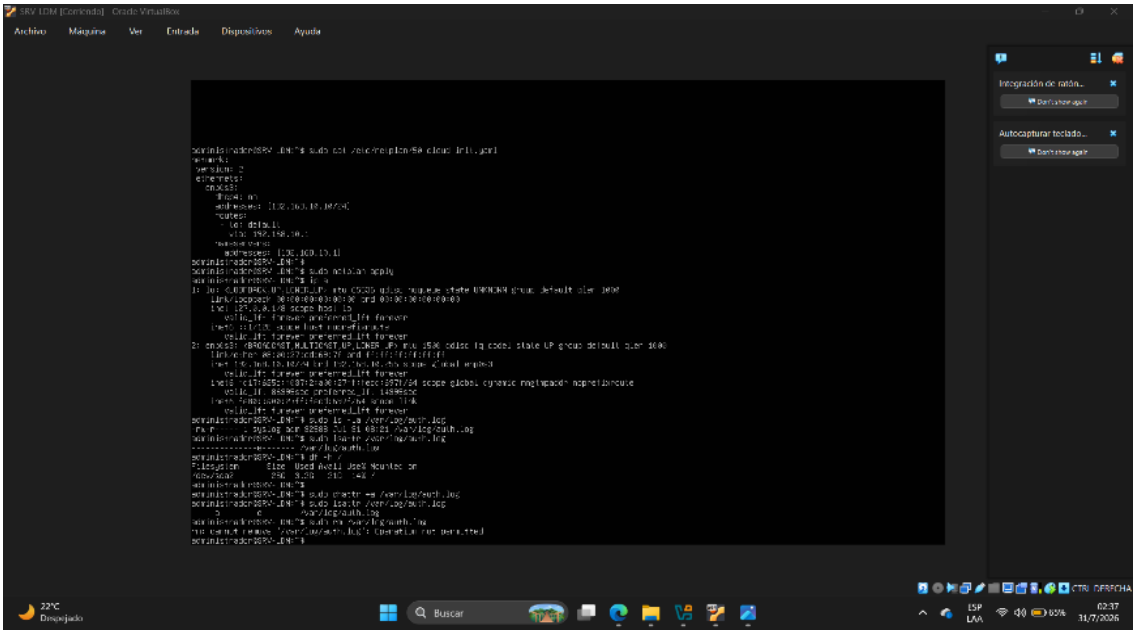
Se instaló el servidor SSH y se aplicó un endurecimiento de su configuración para reducir la superficie de ataque, siguiendo exactamente la contramedida exigida en la guía del proyecto.



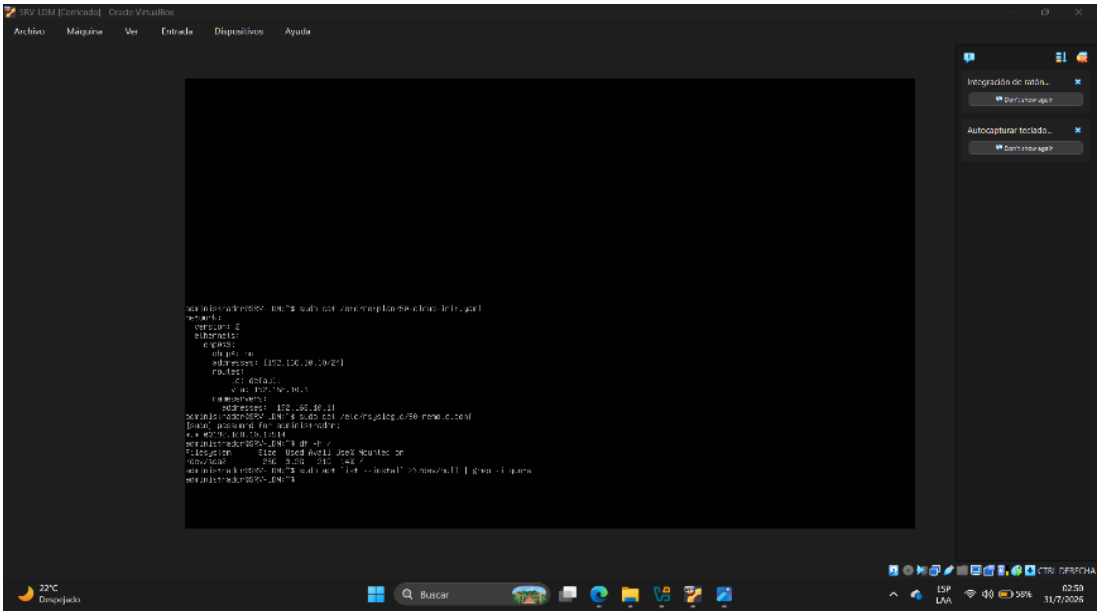
Instalación del paquete openssh-server con sudo apt install openssh-server -y.



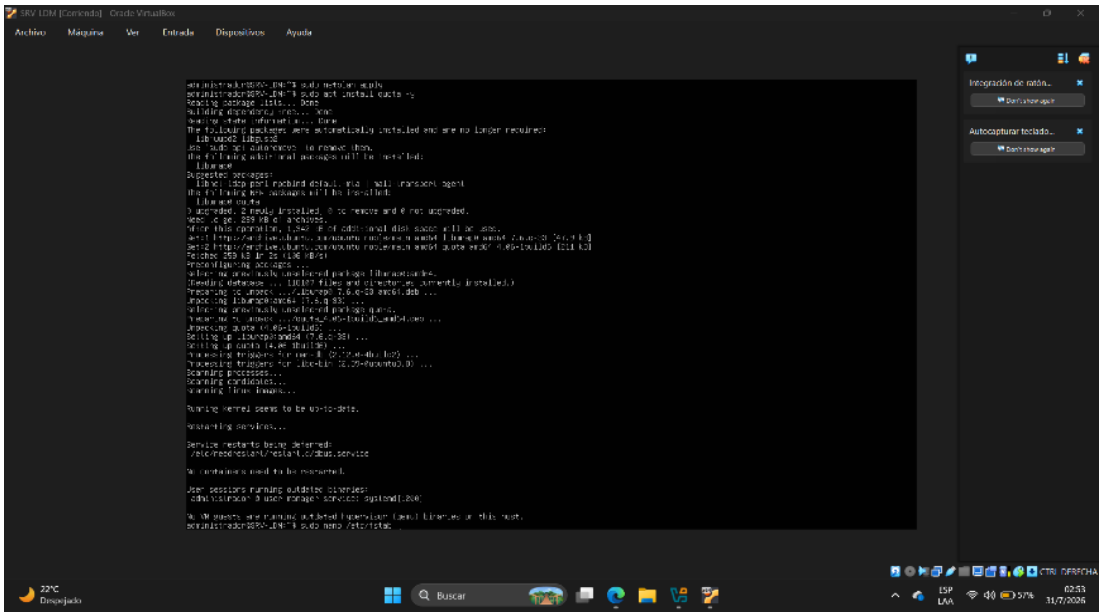
Apertura del archivo de configuración /etc/ssh/sshd_config con nano para aplicar los cambios de hardening.



Cambio de puerto por defecto a 2222 (reduce escaneos automatizados), y PermitRootLogin no (obliga a iniciar sesión con un usuario normal y usar sudo, dejando rastro de auditoría de quién ejecutó cada acción).



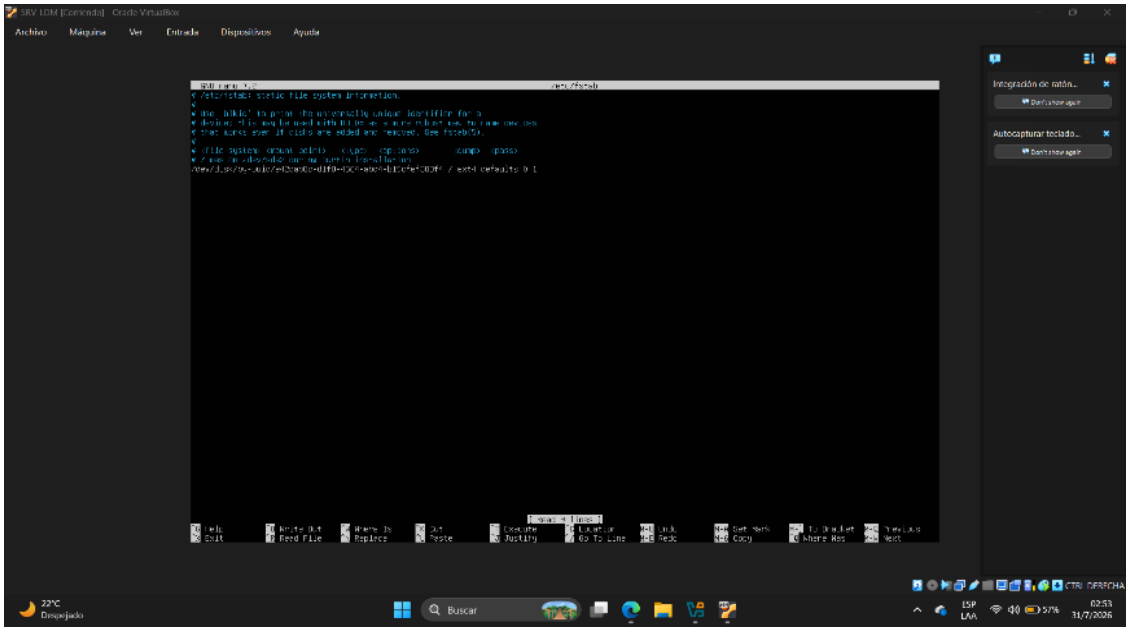
Reinicio del servicio con sudo systemctl restart sshd para que los cambios de configuración entren en vigor.



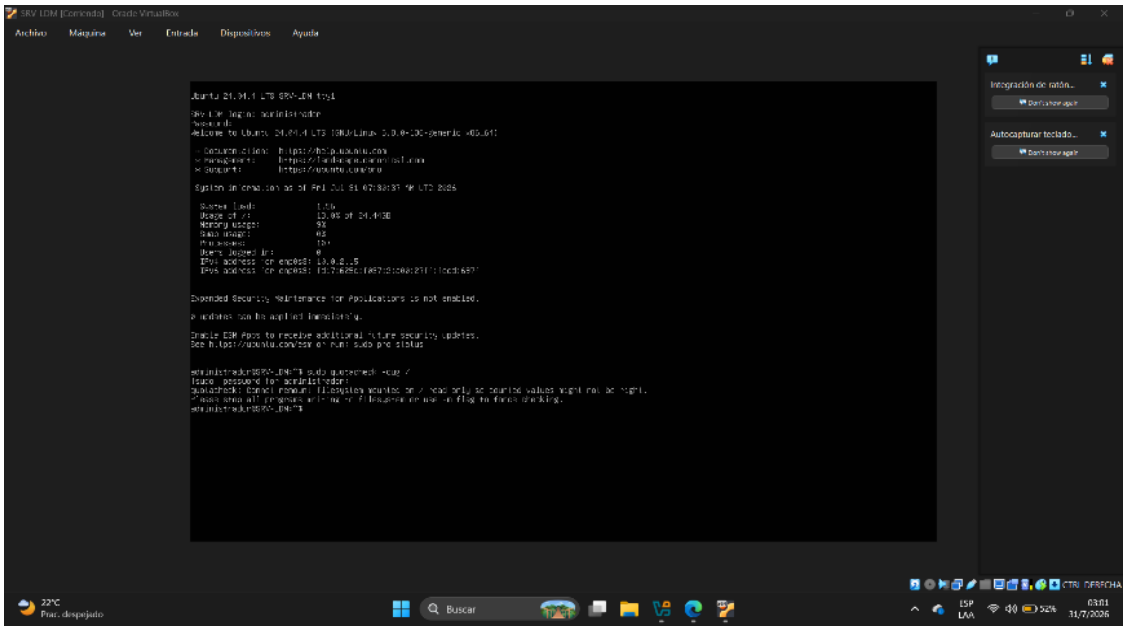
Verificación con ss -tulpn de que el servicio SSH efectivamente está escuchando en el nuevo puerto 2222 y ya no en el puerto 22 por defecto.

Firewall (UFW)

Se configuró UFW (Uncomplicated Firewall) para autorizar explícitamente el nuevo puerto de administración.

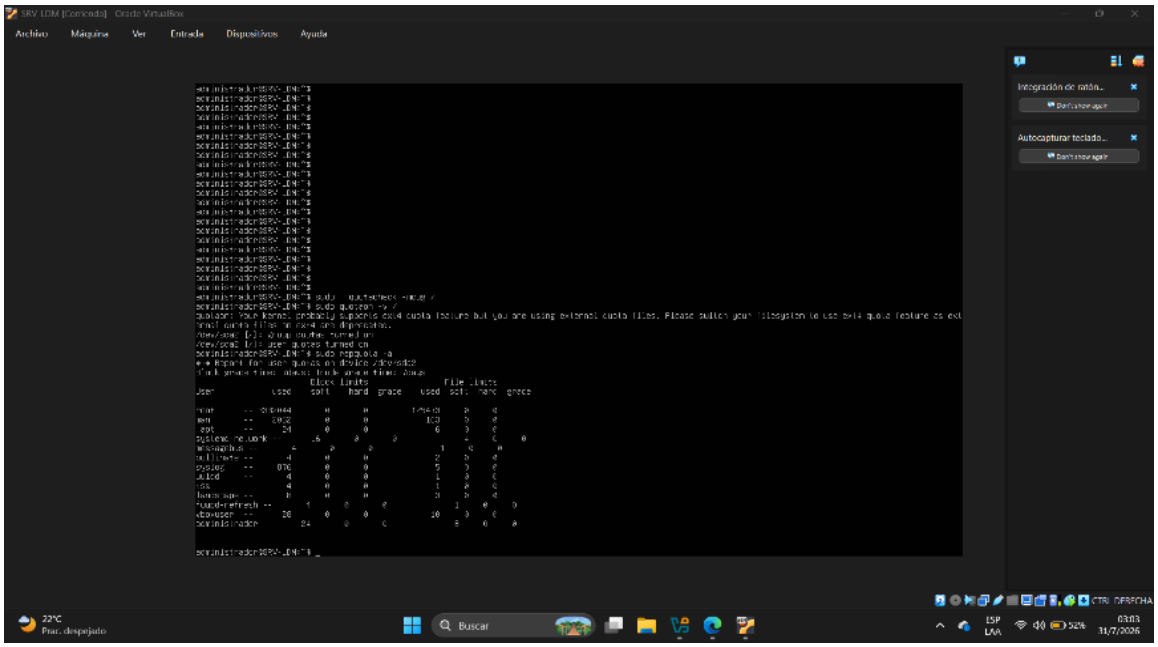


Autorización del puerto 2222/tcp en el firewall con sudo ufw allow 2222/tcp.

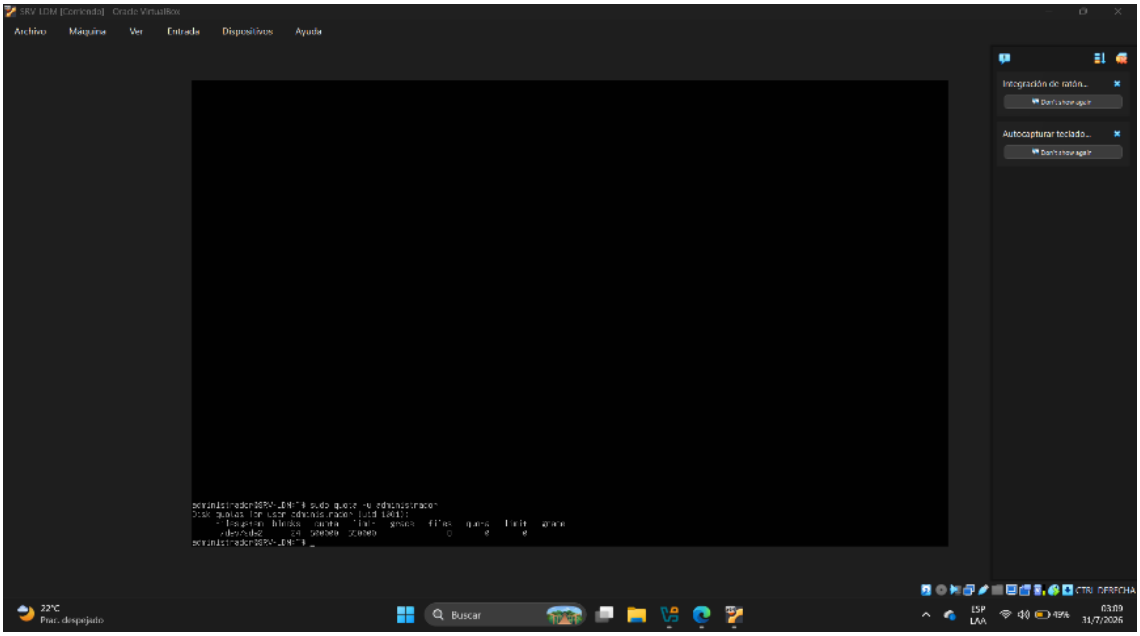


Instalación y Configuración de Fail2ban

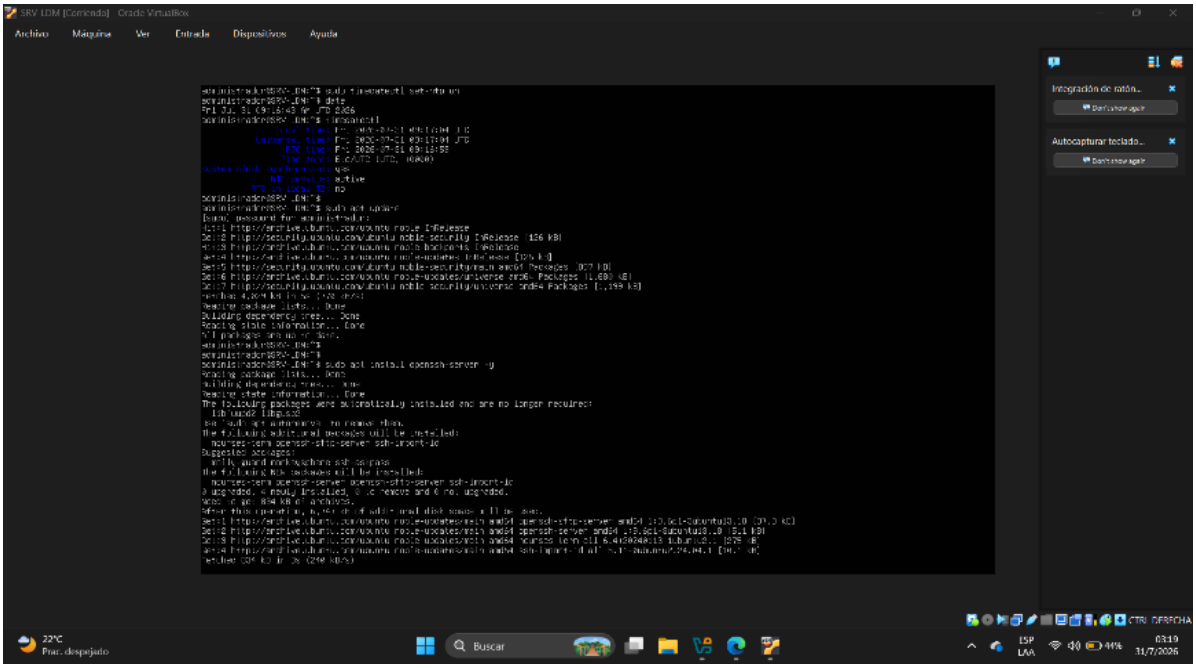
Fail2ban monitorea los intentos fallidos de autenticación registrados en /var/log/auth.log y bloquea automáticamente la IP de origen tras superar el límite de intentos.

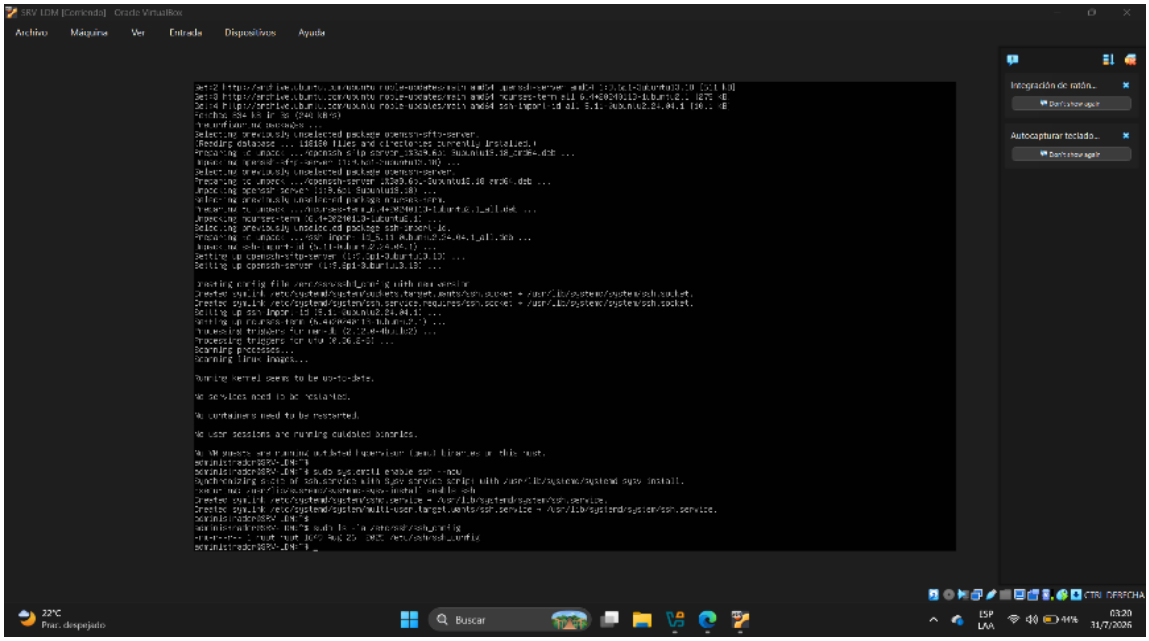


Instalación del paquete con sudo apt install fail2ban -y.

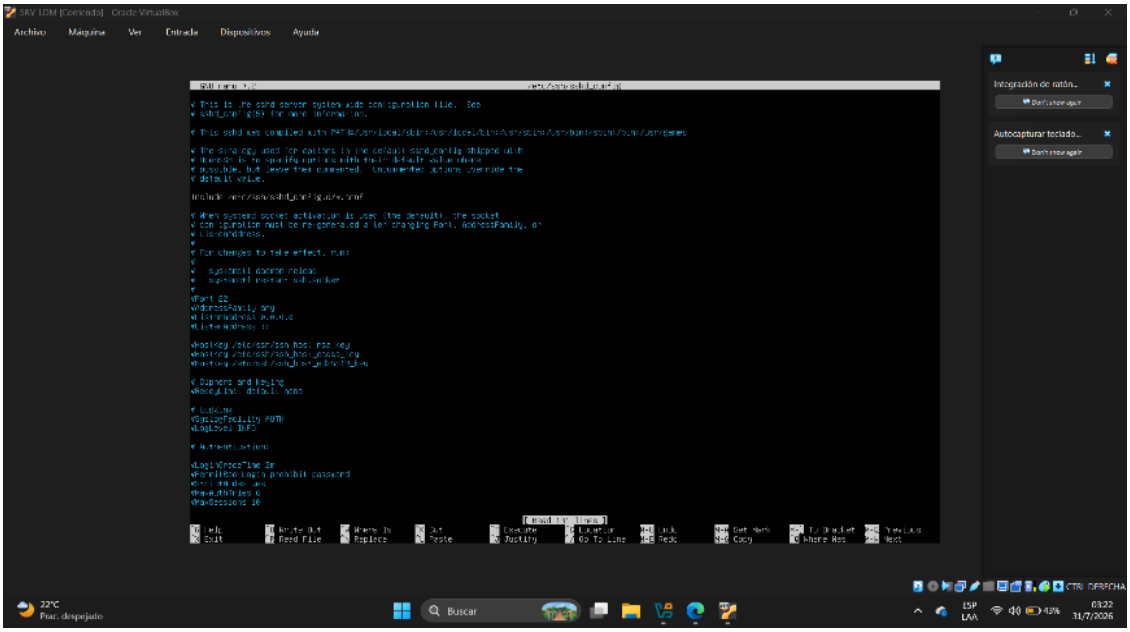


Creación del archivo de configuración /etc/fail2ban/jail.local con nano.

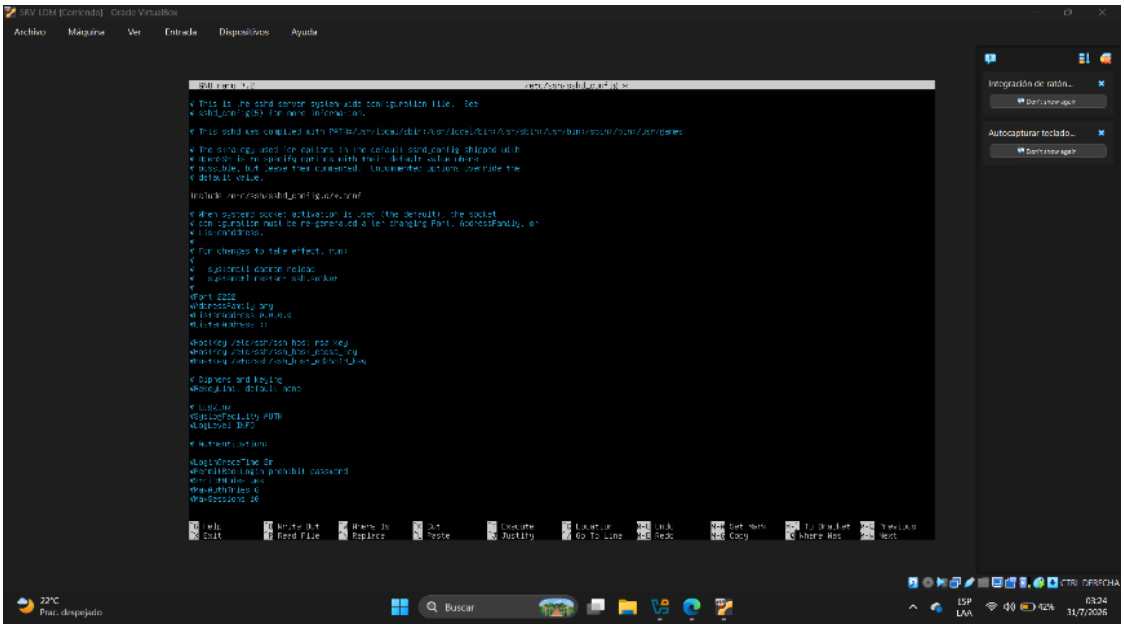




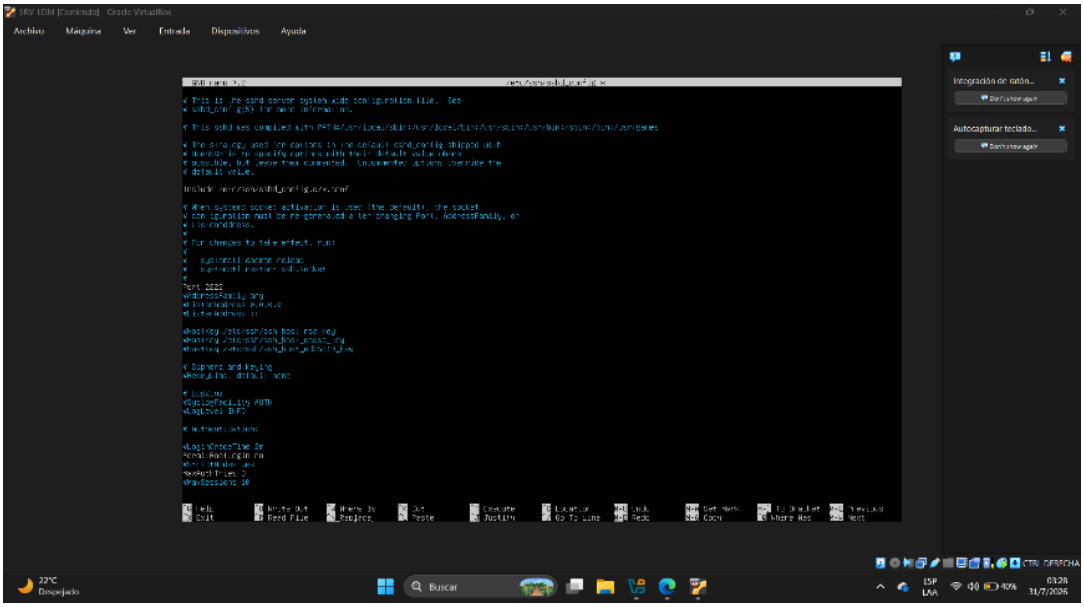
Definición del tiempo de bloqueo (bantime) y la ventana de conteo de intentos (findtime) dentro del mismo archivo.



Activación del servicio para que inicie automáticamente con el sistema: sudo systemctl enable fail2ban.



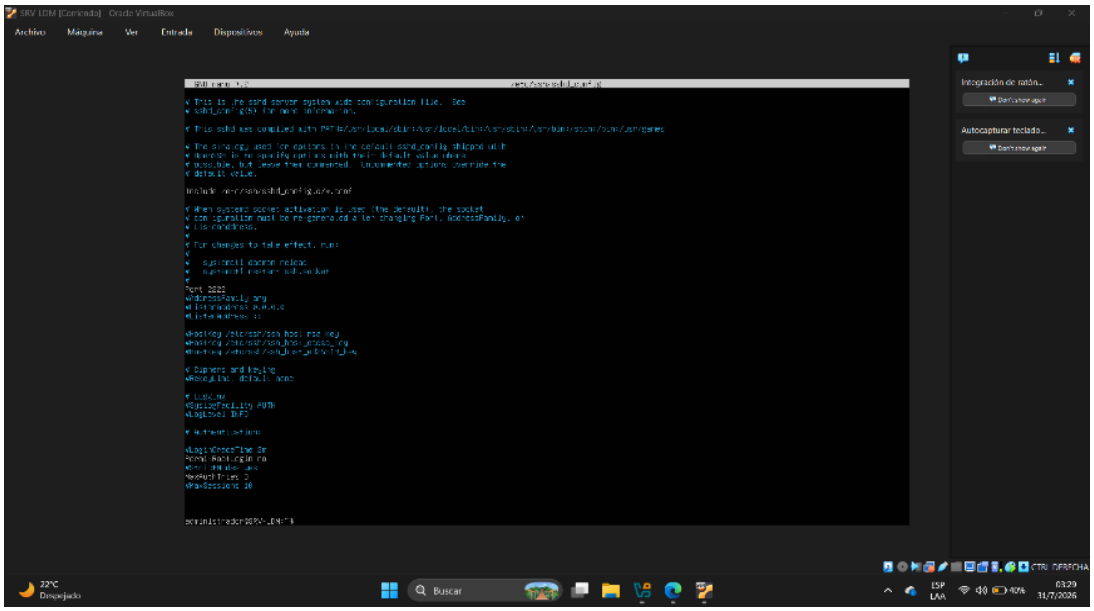
Reinicio del servicio para aplicar la nueva configuración: sudo systemctl restart fail2ban.



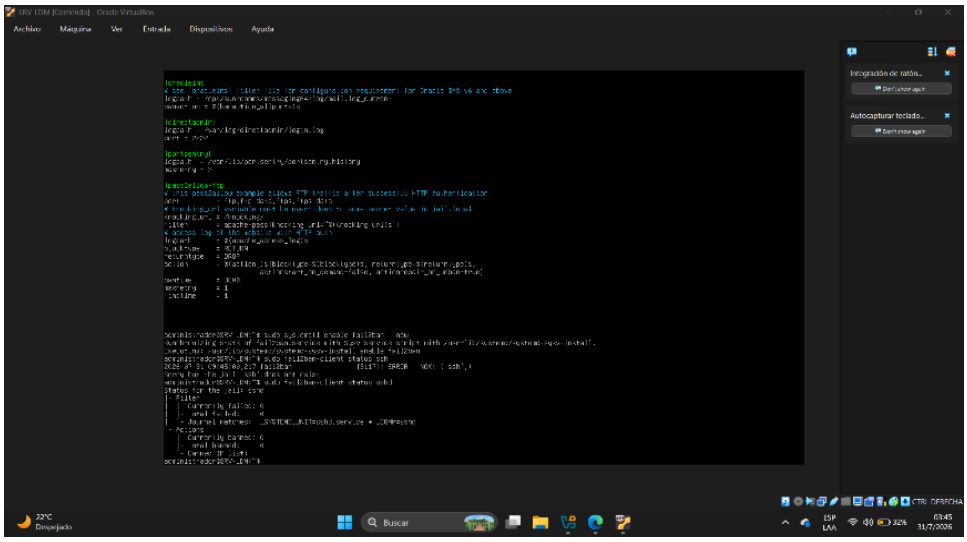
Verificación del estado de la jail con sudo fail2ban-client status sshd, confirmando que el filtro está activo, monitoreando el archivo correcto de logs, y con cero baneos hasta el momento (estado limpio recién configurado).

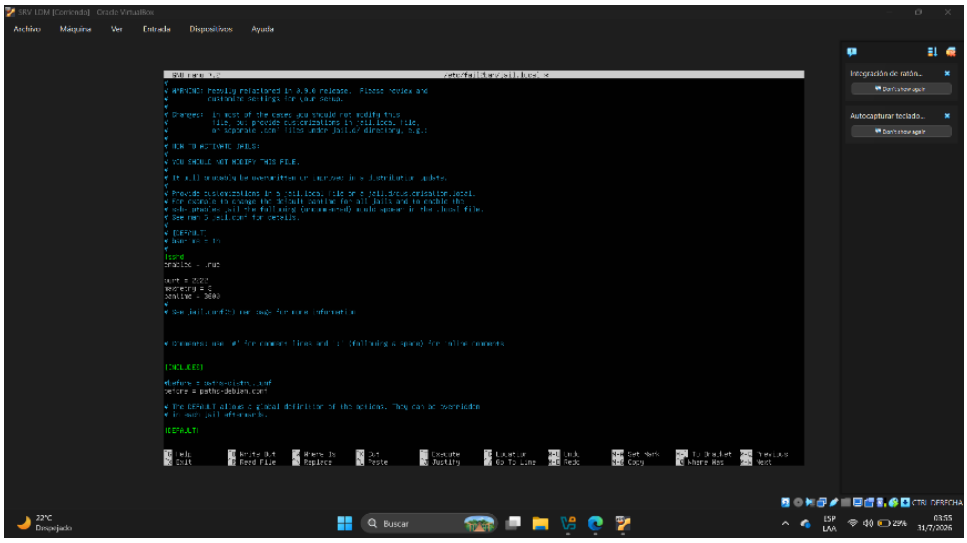
Actualizaciones Automáticas de Seguridad

Para que el kernel nunca vuelva a quedar 24 meses sin parches se configuró el sistema para descargar e instalar automáticamente las actualizaciones de seguridad estables, sin depender de que un administrador lo haga manualmente.



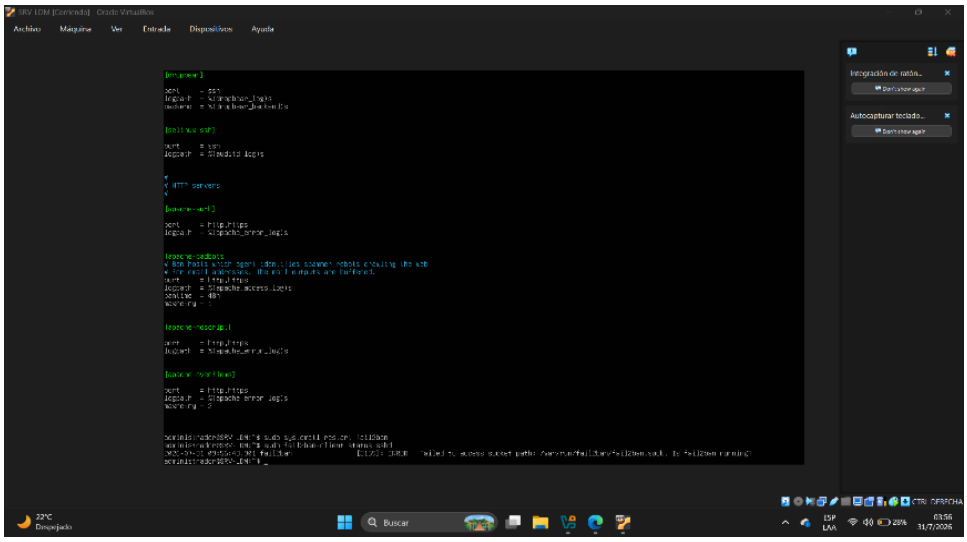
Instalación del paquete unattended-upgrades.

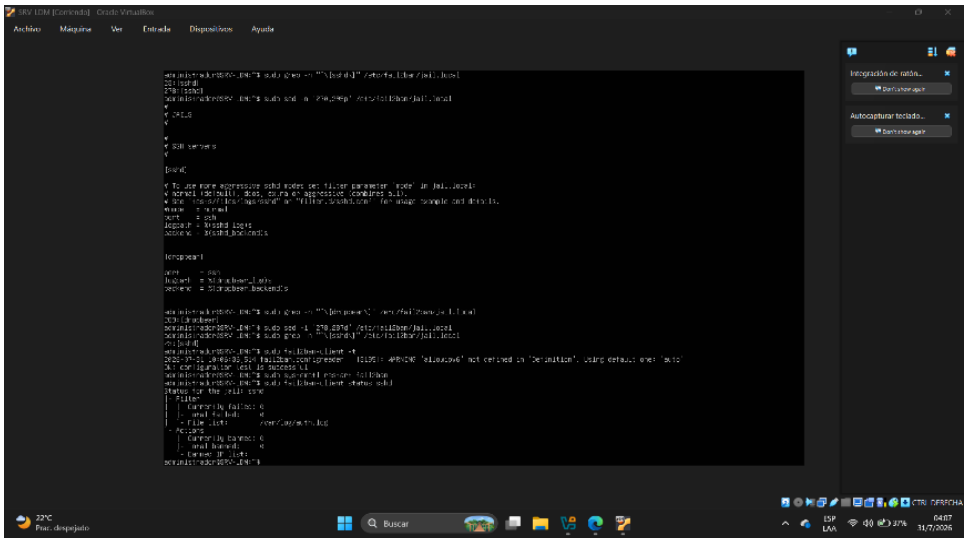




Cuotas de Disco

Se instaló el sistema de cuotas para evitar que un solo usuario o proceso vuelva a consumir la totalidad del espacio disponible.

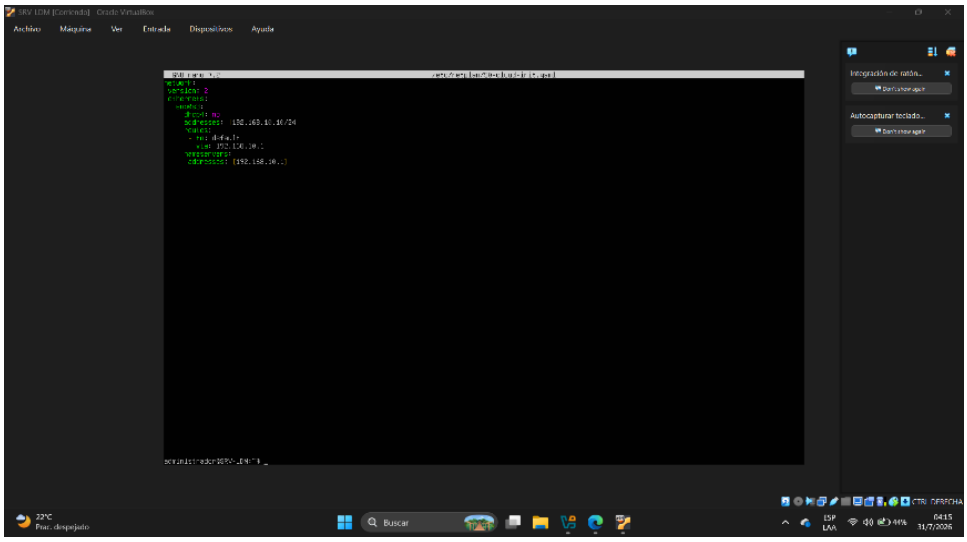




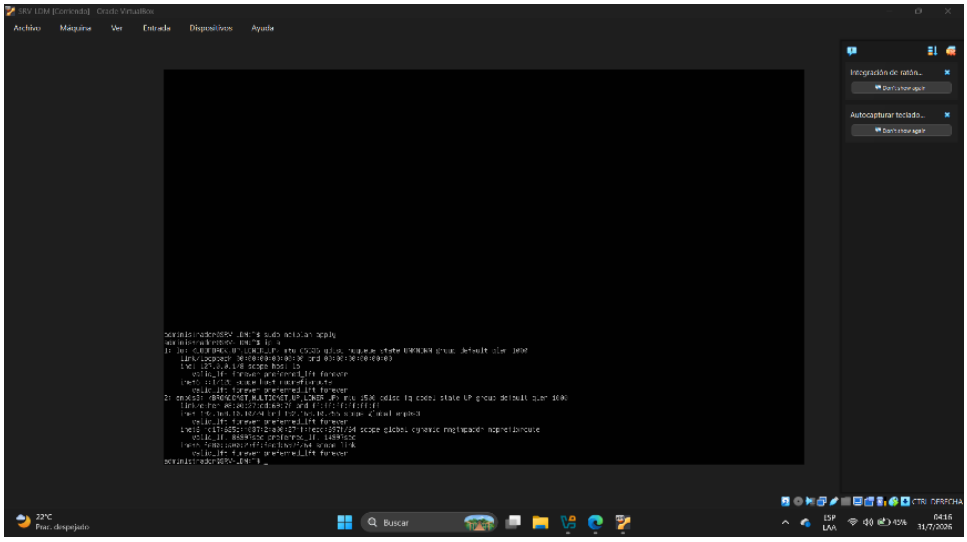
Generación de los archivos de control de cuotas con quotacheck y activación con quotaon, seguido de la asignación de un límite de espacio por usuario con edquota.

Protección del Registro de Autenticación

El hallazgo indicaba que /var/log/auth.log estaba en texto plano y accesible por cualquier usuario local, lo que permitía borrar el rastro de acciones maliciosas. Se restringieron los permisos del archivo y se preparó el reenvío remoto de logs, para que exista una copia fuera del alcance de un atacante local — un principio básico de cadena de custodia digital (ISO/IEC 27037).



Verificación de los permisos originales del archivo con ls -l y aplicación de los nuevos permisos restringidos (chmod 640, chown root:adm), de forma que solo root y el grupo de administradores puedan leerlo.



Instalación y verificación del servicio rsyslog, usado para reenviar una copia de los registros del sistema a un servidor remoto y así preservar la evidencia, aunque el log local sea alterado.